

Helix Health

Board and Clinical-Leadership Briefing

DOCUMENT ID	VERSION	PERIOD
IJZ-HLX-BOARD-20260627	v3.0	FY 2026 Q2
PREPARER	CLASSIFICATION	STATUS
Ijezie Risk Advisory	CONFIDENTIAL	Draft - Pending Review

Helix Health Board + Clinical-Leadership Briefing

Document Type: Quarterly Board + Clinical-Leadership Briefing **Audience:** Board of Directors + Clinical Advisory Board + CEO + CFO **Engagement:** Helix Health Inc. **Period:** FY 2026 Q2 (reporting period April 1 - June 30) **Briefing Date:** 2026-06-27 **Briefing Authority:** Ijezie Risk Advisory (vCISO)

1. Audience Note: Why This Briefing is Different From a SOC 2 Board Briefing

A Helix Health board briefing is **not** the same audience or content as a FinTech SOC 2 board briefing. The Helix board includes a Clinical Advisory Board with practicing physicians, nurses, and clinical informaticists. They are concerned about:

- Patient safety implications of security events
- Clinical workflow disruption from security controls
- HIPAA regulatory exposure (OCR + state AGs + class-action)
- BAA-covered customer trust (provider organizations and payer partners)
- Series C investor due diligence signals
- HITRUST CSF certification timeline impact

This briefing addresses those concerns explicitly. It is not a generic "we have N risks at residual M" summary.

2. Executive Summary (60-Second Read)

DIMENSION	CURRENT STATE
HIPAA Risk Analysis	Complete, OCR-defensible per §164.308(a)(1)(ii)(A)
Risk profile	0 Very High, 7 High, 5 Moderate (residual)
BAA coverage	10 of 10 BAA-covered vendors with executed BAAs
BAA renewals at risk	3 vendors within 60 days (Auth0, Sumo Logic, Google Workspace)
Breach notification readiness	Playbook complete, quarterly drills scheduled
SOC 2 Type 2 observation	6 months in (started 2026-01-01)
HITRUST CSF certification	Targeted Q4 2026, on track
HDS v2.0 readiness	Pre-EU expansion - documentation gap exists

Bottom line: HIPAA posture is strong, OCR audit-defensible. Three BAA renewals need immediate attention. HITRUST CSF Q4 certification is on track. No board-level action required this quarter.

3. Risk Posture (Board-Relevant Subset)

Of 12 risk scenarios, **4 are board-relevant** because they require board awareness, executive sponsorship, or external disclosure if they materialize.

RISK ID	SCENARIO	RESIDUAL	BOARD-RELEVANT RATIONALE
HH-R-02	BAA-covered vendor breach exposing PHI	Moderate (4)	BAA dependency. Affects 4 vendor relationships. If realized, triggers 60-day HIPAA notification chain.
HH-R-04	Provider EHR connector compromise (supply chain)	Moderate (9)	Supply chain risk. Cannot be eliminated because EHR vendors (Epic, Cerner, Athena) are themselves BAs. Affects 37 provider customers.
HH-R-05	HIPAA breach notification failure (60-day rule)	Moderate (4)	Operational risk. Failure has direct regulatory consequence (CMPs + OCR investigation + customer churn).
HH-R-08	Inadequate downstream BAAs	Moderate (4)	BAA dependency. 10 vendors, 3 renewals due within 60 days.

The remaining 8 scenarios are management-level. They are tracked in the risk register but do not require board awareness.

4. Clinical Safety Implications (New Section)

Clinical safety is the dimension that does NOT appear in FinTech board briefings. Helix's clinical leadership cares about:

4.1 Patient Safety Risks from Security Events

RISK ID	CLINICAL SAFETY IMPLICATION
HH-R-01 Ransomware	PHI inaccessibility during ransomware attack delays clinical decisions. Provider staff may operate without patient history for 4-24 hours.
HH-R-04 EHR Connector Compromise	Incorrect or stale data flowing between Helix and provider EHR systems could lead to wrong clinical decisions.
HH-R-09 Audit log tampering	Loss of audit trail means providers cannot demonstrate what data was reviewed for which patient. Medico-legal risk.

4.2 Clinical Workflow Disruption from Security Controls

Security controls can introduce friction in clinical workflows. The vCISO must balance security with clinical efficiency:

CONTROL	CLINICAL IMPACT	MITIGATION
MFA enforcement (HH-R-07)	Adds ~5 seconds per login	Auth0 session extension (15 min idle, 8 hr max)

CONTROL	CLINICAL IMPACT	MITIGATION
Provider portal session timeout	Logs out providers mid-encounter	Configurable session extension per role
Background check requirement	Delays onboarding of clinical staff by 3-7 days	Pre-offer background check (instead of post-offer)
Quarterly access attestation	Burden on provider IT teams	Self-service attestation portal (planned Q4 2026)

4.3 Clinical-Led Risk Acceptance Decisions

Some security risks require clinical judgment to accept or escalate:

DECISION	CLINICAL INPUT NEEDED
HH-R-06 (AWS region failure) - accepted	Clinical impact: regional outage delays patient care for up to 4 hours. Clinical board may want to escalate.
HH-R-04 (EHR connector compromise) - residual Medium	Clinical board should review whether residual risk is acceptable given patient safety implications.
New high-severity risk during the period	Clinical board should review within 30 days if patient safety is implicated.

5. HIPAA Regulatory Posture

5.1 OCR Audit Defensibility

Helix is ready for an OCR investigation at any time. The HIPAA Risk Analysis (this quarter's deliverable) meets the OCR Audit Protocol requirements:

- Accurate and thorough assessment of ePHI risks
- Maps to all 12 HIPAA Security Rule safeguard families
- Quantitative scoring (5x5 risk matrix)
- Honest residual risk reporting
- Documented POA&M with ownership
- Cross-referenced to required documentation set

5.2 Recent Regulatory Activity (No Action Required)

- HHS/OCR 2024 enforcement priorities: ransomware response + reproductive health data + AI in clinical decision-making. Helix is not directly targeted by any of these priorities.
- State-level activity: California's CPPA (California Privacy Protection Agency) is increasing HIPAA-adjacent enforcement. Helix does not process CA resident data directly but BAA-covered providers do. No direct impact.
- HIPAA modernization: HHS/OCR proposed updates to the HIPAA Privacy Rule in 2024 (final rule expected 2026). The proposed updates include strengthening reproductive health data protections and removing the Notice of Privacy Practices requirement for certain disclosures. Helix should monitor for final rule publication.

5.3 HIPAA-Specific POA&M (7 Open Items)

POA&M ID	RISK	ACTION	OWNER	TARGET
POA&M-01	HH-R-01	EDR rollout to production hosts	CISO	Q3 2026
POA&M-02	HH-R-02	SOC 2 Type 2 collection from Tier 1 vendors	TPRM	Q4 2026
POA&M-03	HH-R-03	Privileged access workstation (PAW)	CISO	Q4 2026
POA&M-04	HH-R-04	Vendor security questionnaires for EHR connectors	TPRM	Q3 2026
POA&M-05	HH-R-05	Quarterly breach notification drill	Compliance	Q3 2026
POA&M-06	HH-R-08	BAA review for downstream vendors	Legal + TPRM	Q3 2026
POA&M-07	HH-R-12	Annual key rotation automation	Engineering	Q4 2026

6. BAA Vendor Risk Posture (Board-Relevant)

6.1 Critical BAA Renewals (3 Within 60 Days)

VENDOR	RENEWAL DATE	DAYS OUT	ACTION REQUIRED
Google Workspace	2026-08-20	55 days	Initiate renewal Q3 2026
Auth0 (Okta CIC)	2026-09-10	76 days	Initiate renewal Q3 2026
Sumo Logic	2026-09-10	76 days	Initiate renewal Q3 2026

If any of these BAAs expire without renewal, Helix is **prohibited from disclosing PHI to that vendor**. PHI flow to Auth0/Google Workspace/Sumo Logic must stop immediately upon expiry until renewal is complete.

Recommended board action: Approve accelerated BAA renewal authority for Legal + TPRM to execute renewals within 30 days of expiration without requiring full board approval for each.

6.2 BAA Concentration Risk

AWS is the underlying infrastructure for 4 of the 10 BAA-covered vendors (Datadog, Auth0, Sumo Logic, plus direct use). A single AWS incident could affect 4 vendor BAAs simultaneously. This is monitored quarterly per the BAA Policy but represents structural concentration.

7. SOC 2 Type 2 Observation Window Status

SOC 2 Type 2 observation period began 2026-01-01. As of 2026-06-27, the observation is 6 months in. The Type 2 report will cover the full 12-month period (2026-01-01 to 2026-12-31).

7.1 Observation Status

- Days elapsed: 178 of 365
- Days remaining: 187
- Auditor on-site visits: 2 completed (Q1 financial review, Q2 IT general controls)
- Open observation items: 4 (all remediation in progress)

7.2 Type 2 Audit Schedule

DATE	ACTIVITY
2026-12-31	Observation period ends
2027-01-15	Auditor fieldwork begins
2027-02-15	Draft Type 2 report
2027-03-15	Final Type 2 report + management letter

8. HITRUST CSF Certification Status (Target Q4 2026)

HITRUST CSF certification is in progress. The certification authority is the HITRUST Alliance, and the submission platform is MyCSF.

8.1 Certification Path

PHASE	STATUS
Self-assessment (Q1 2026)	Complete
Pre-certification readiness review (Q2 2026)	In progress
Validated assessment (Q3 2026)	Scheduled with HITRUST Alliance
Certification issuance (Q4 2026)	On track

8.2 Critical Gap

HITRUST CSF v11 is not in the CISO Assistant v3.18.3 catalog. Helix cannot formally track HITRUST requirements in CISO Assistant. The vCISO recommendation is to either (a) upgrade CISO Assistant when HITRUST CSF v11 becomes available, or (b) track HITRUST requirements separately in MyCSF. The cross-walk document maps HIPAA + SOC 2 + HITRUST requirements at the control level, so manual MyCSF tracking is feasible.

8.3 HITRUST ROI

HITRUST certification is a sales enabler for enterprise healthcare customers. Multiple Helix provider customers have HITRUST as a procurement requirement. Certification is estimated to:

- Enable \$3-5M in additional annual recurring revenue (Series C pipeline)

- Reduce customer security questionnaire burden by ~40%
- Support HDS v2.0 (French healthcare hosting) pre-certification activities

9. What This Demonstrates

This board briefing shows healthcare-specific vCISO work:

1. **Clinical Safety Implications section.** This is the dimension that does NOT appear in AtlasPay or other industry briefings. Patients are at stake, not just data.
2. **Clinical Workflow Disruption analysis.** Security controls can introduce friction in clinical workflows. The vCISO must balance security with clinical efficiency.
3. **Clinical-Led Risk Acceptance Decisions.** Some risks (HH-R-06 regional outage, HH-R-04 EHR connector compromise) require clinical judgment to accept or escalate.
4. **OCR Audit Defensibility explicit.** This is the regulator-specific framing that healthcare requires. SOC 2 auditors and OCR auditors are different audiences with different concerns.
5. **HITRUST certification status.** A third framework on top of HIPAA + SOC 2. The vCISO tracks all three.
6. **BAA renewals with hard deadlines.** HIPAA prohibits PHI disclosure to a vendor with an expired BAA. This is operationally different from a vendor contract with a lapsed SLA.
7. **Patient Safety as the primary risk dimension.** In FinTech, the primary risk dimension is financial. In healthcare, it is patient safety. The board briefing reflects this.

10. Asks of the Board

ASK	RATIONALE	APPROVER
Approve accelerated BAA renewal authority for Legal + TPRM	3 BAAs renew within 60 days; full board approval each time delays execution	Board
Approve budget for HITRUST CSF validated assessment (~\$30-50K)	Required for Q4 2026 certification	Board
Approve budget for PAW implementation (~\$15K)	Required for HH-R-03 closure	CISO (within budget)
Approve quarterly breach notification drill as standing practice	Required for HH-R-05 mitigation	Board
Note HITRUST CSF v11 catalog gap; consider CISO Assistant platform upgrade	Affects Q4 certification efficiency	CISO

11. Review and Update Schedule

- Quarterly briefing (Q3, Q4, Q1, Q2)
- Ad-hoc briefing on any board-relevant risk materialization

-
- Annual refresh with Clinical Advisory Board input

Owner: CISO (Ijezie Risk Advisory) **Approver:** Board of Directors + Clinical Advisory Board